

Insider Threat as a Public Health Problem

From Incident Response to Organizational Wellness

Rob Knowles · OSIT Summit · CMU SEI

Press  *to begin.*

PRESENTER CONTROLS

→ / Space advance · ← back · F fullscreen

R reveal all · ? help

Built in HTML with Anthropic Claude. Single file. No dependencies.

Why I'm here.

Rob Knowles · Principal Insider Threat Analyst · Navy
Federal Credit Union

linkedin.com/in/robknowles-cybersecurity

CREDENTIALS

M.S. Applied Information
Technology — George Mason
University

CISSP · GCITP · CEH

A+ · Net+ · Sec+

BOARDS & WORKING GROUPS

Chair, FS-ISAC InT Working
Group Steering Committee

Active: OSIT · NCFTA · ATAP

insiderthreatanalyst.com

(also: feeding CEUs · dodging the day job)

Where we're going.

ONE

Problem

*What we're
seeing.*

TWO

Playbook

*What's already
here.*

A conceptual model.

THREE

Proposal

*What I'm
suggesting.*

Problem

What we're seeing.

1. *Why insider threat is a base-rate problem*
2. *Desire paths — and what AI does to them*
3. *Why current responses don't work*

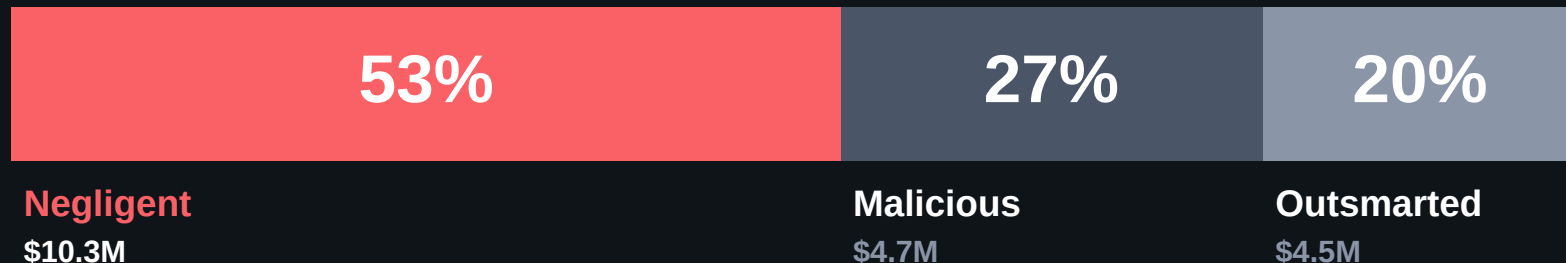
**"When you hear hoofbeats,
think horses, not zebras."**

— *Theodore Woodward, 1940s*

The expensive truth

\$19.5M average annual cost of insider incidents per organization

in 2025 — up from \$17.4M the year before



Ponemon Institute & DTEX. Cost of Insider Risks Global Report 2026.

Desire paths

The paved walkway goes one way.

The worn grass goes the other.

The grass is where people actually walk.



Nurse, Creese, Goldsmith, Lamberts (2011). "Guidelines for usable cybersecurity."

What that looks like

Three desire paths. Every one of them in your queue right now.

Personal email.

VPN was flaky. Kid was sick. The file had to move.

Unsanctioned AI.

Copilot can't do what the work needs it to do.

Mouse mover.

Status went yellow. My manager asked why I wasn't working.

Shadow AI is the leading driver of negligent insider cost

The accelerant

AI didn't create desire paths. It just got the workforce sprinting down them.

65%
“Use AI — or get left behind.”

of US knowledge workers use AI tools for work.

58%

received no training on doing it safely.

43%

And it just got faster.

AI multiplies the horses faster than the analysts can sort them.

Mostly horses.

Every desire path generates an alert.



Same playbook, same trajectory.

The default response: more training, harsher penalties. Here's what that buys.

DARE

Drug Abuse Resistance Education

Effect size: Cohen $d \approx 0.02$.

10-year follow-up: no measurable effects.

\$750M/year at peak. 75% of US districts.

The most evaluated drug-prevention program in history.

Playbook

What's already here.

1. *The lever — read the conditions, change the conditions*
2. *Three frameworks at three scales*
3. *AI as the engine; new metrics for a new model*

Read the conditions. Fix the conditions. The same move does both.

Less workforce noise.

Friction signals down. Desire paths shrink. Negligence chops.

More analyst attention.

Cognitive tunnel widens. Peripheral signal returns. Zebras visible again.

From measurement to meaning

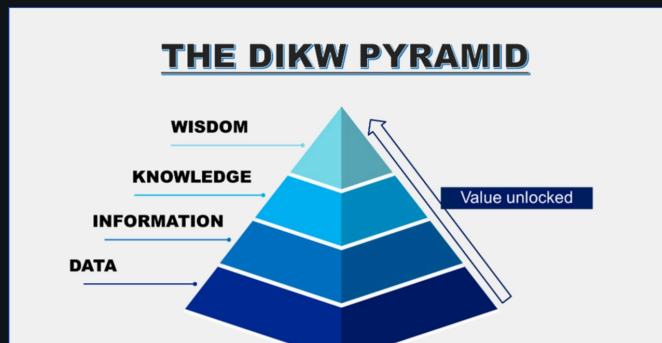
The tools are deployed. The data is in your stack. The wisdom is the climb.

What we
measure today

Incidents closed.

Alerts
processed.

Mean time to



What we
should ask

Why is this
happening?

Where is the
pattern?

What would

Three frameworks. Three scales.

Case. Environment. Population. The through-line is already drawn.

CASE

Insider Threat Matrix

TTP coding

ATT&CK-style
coding for

ENVIRONMENT

SOFIT

Greitzer

Sociotechnical
&
organizational
factors. The
conditions

POPULATION

Behavioral Drift

predictive signal

Deviation →
Normalization →
Escalation. What

The Insider Threat Matrix.

ATT&CK-style coding. Applied to insider cases.

Motive

Why

Means

*Access
& tools*

Preparation

*Recon &
planning*

Infringement

The action

**Anti-
Forensics**

Concealment

Five themes. 350+ documented techniques. A common vocabulary for the case archive.

Open. Free. Apache 2.0.

SOFIT.

Sociotechnical & Organizational Factors. The conditions around the case.

What it is

A factor ontology — hundreds of named, defined factors covering individual psychosocial state, work context, technical environment, and organizational climate.

Frank Greitzer's work; cumulative refinement over a decade-plus of

Why it matters here

Where ITM gives you the technique-layer coding, SOFIT gives you the factor-layer scoring underneath.

Scoreable indicators underneath the case — not just qualitative codes.

Behavioral Drift.

Behavioral drift. What the workforce is doing at the policy edges.

Deviation

One person bends the
rule. →

Normalization

The team does.
Nothing breaks. →

Escalation

The next bend is
bigger. By then it's
culture.

A predictive signal, not a postmortem. The shape of how rules quietly stop mattering — visible in the data *before* anything becomes a case.

Turn them around, don't turn them in.

Mature InT programs already say this. Public health builds it into the system.

Volume infringement tracking

What is the population doing at the policy edges?

Desire-path audits

Where is the grass worn down?

SOFIT factor scoring

What conditions surround the case?

Proposal

What I'm asking.

1. *Three things to try this week*
2. *The engine — what AI does that no analyst team can*
3. *Ethical — what we have to be honest about while doing it*
4. *New metrics — what to measure when the goal is conditions*
5. *Homework — the frameworks, freely available*

Three things to try.

No budget. No org chart change. Just a different question.

Check your top 3 security exceptions.

Why do they have to be excepted? Could you approve them for everyone safely? If yes — why haven't you? If no — what's the safe alternative that does what the work actually needs?

Concrete example: unauthorized software installs (think Notepad++). Watch the responses across cases — that variance is itself the signal.

Code one case to ITM in your next case review.

Pick a recent case. Walk it through the five themes — motive, means, preparation, infringement, anti-forensics. Note what techniques apply and

The engine.

AI does for these frameworks what no analyst team can.

ITM auto-coding

Every case note, every ticket — coded into ITM techniques at population scale, not sample.

SOFIT factor scoring

Hundreds of factors against telemetry and HR signal,

Volume infringement detection

Drift surfaces before it becomes violation volume.

Retrospective analysis

Latent structure across the historical archive — because no

Ethical.

Naming what this is. Naming what it can become.

Surveillance, named

Continuous
behavioral
monitoring across
HR and telemetry
signal. Call it what it
is.

Existing guardrails

Aggregated by
default. Named
scope, documented
gates.

Disparate impact

Auto-coding inherits
historical bias.
Legal in the room,
non-negotiable.

New metrics for a new model.

Some you can count today. Some you can only point at.

COUNTABLE TODAY

Time-to-intervention

documented action on a surfaced condition

Repeat-offender rate per population segment

by team, role, tenure

DIRECTIONAL

Homework.

Two frameworks. Two free reads. One practitioner site.

Insider Threat Matrix

TTP coding (case scale)
and Behavioral Drift
(population scale).

insiderthreatmatrix.org

SOFIT 2.0

Factor ontology
(environment scale).

cogility.com/blog/sofit2

Practitioner site

This deck & the maps
between frameworks.

insiderthreatanalyst.com

All free. All available. On the shelf.

You can't run primary prevention from one office.

It requires a seat at the table.

And half of programs report difficulty getting one — funding and collaboration from HR, Legal, and Compliance.

Human Resources

Joiner/Mover/Leaver events, climate signal

Employee representation

voice of the population

From detective to preventive.

The model came from public health.

A hundred years of practice in reading populations, not policing individuals.



*If you build for the rare **catastrophe**
then you miss what's actually happening.*

Read the herd.

If anything here was useful —

insiderthreatanalyst.com

/osit → the deck

*The deck, the framework maps, and a CC BY 4.0 practitioner library.
Give me a few days after the talk.*

Thanks for the time

References.

What this talk was built on.

FRAMEWORKS

Insider Threat Matrix. Weston, J. & Beaman, J. (Forscie).

insiderthreatmatrix.org

SOFIT 2.0. Greitzer, F.L. et al.

cogility.com/blog/sofit2

MITRE ATT&CK. attack.mitre.org

FOUNDATIONS

Ackoff, R.L. (1989). “From Data to

INDUSTRY RESEARCH

Cybsafe & National Cybersecurity Alliance.

“Oh Behave! The Annual Cybersecurity Attitudes and Behaviors Report 2025-2026.” cybsafe.com/whitepapers/oh-behave-the-annual-cybersecurity-attitudes-and-behaviors-report-2025-2026

DTEX Systems & Ponemon Institute. “2025 Cost of Insider Risks Global Report.”

ponemon.dtex.ai

PRACTITIONER

insiderthreatanalyst.com — practitioner